Title: Web Application Vulnerability Testing on DVWA

Objective

The objective of this lab is to perform web application penetration testing using both manual and automated techniques. The aim is to identify common vulnerabilities from the OWASP Top 10, such as SQL Injection and Cross-Site Scripting (XSS), and to analyze their impact on application security.

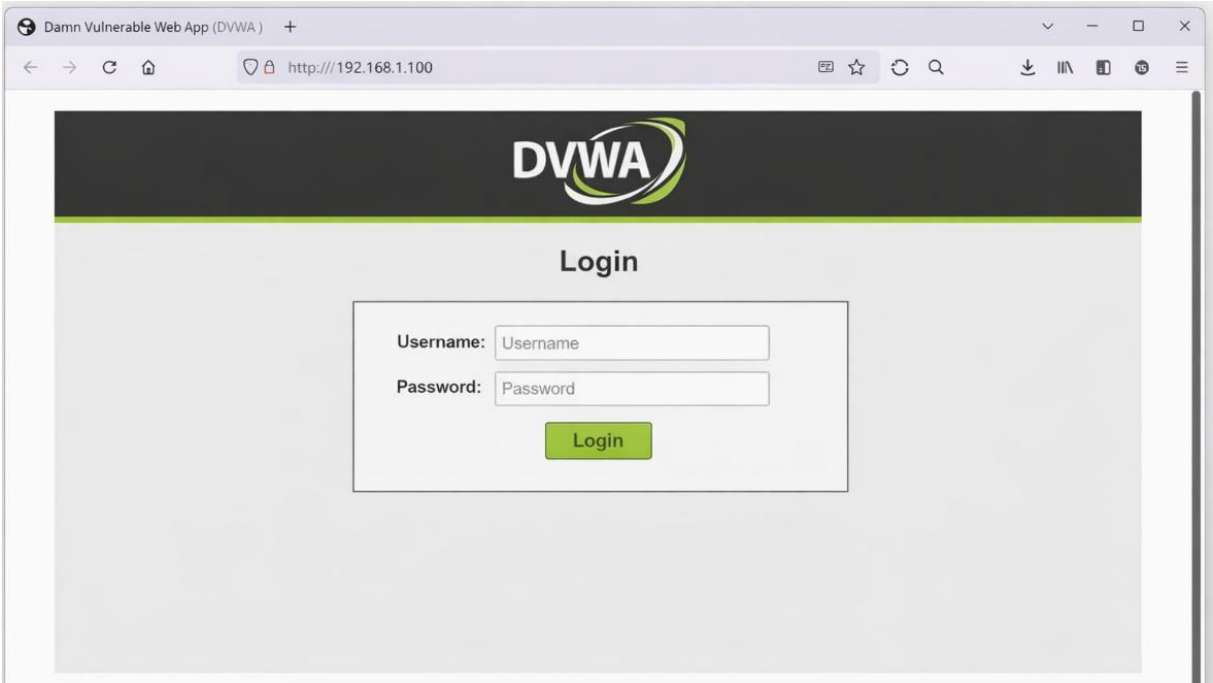
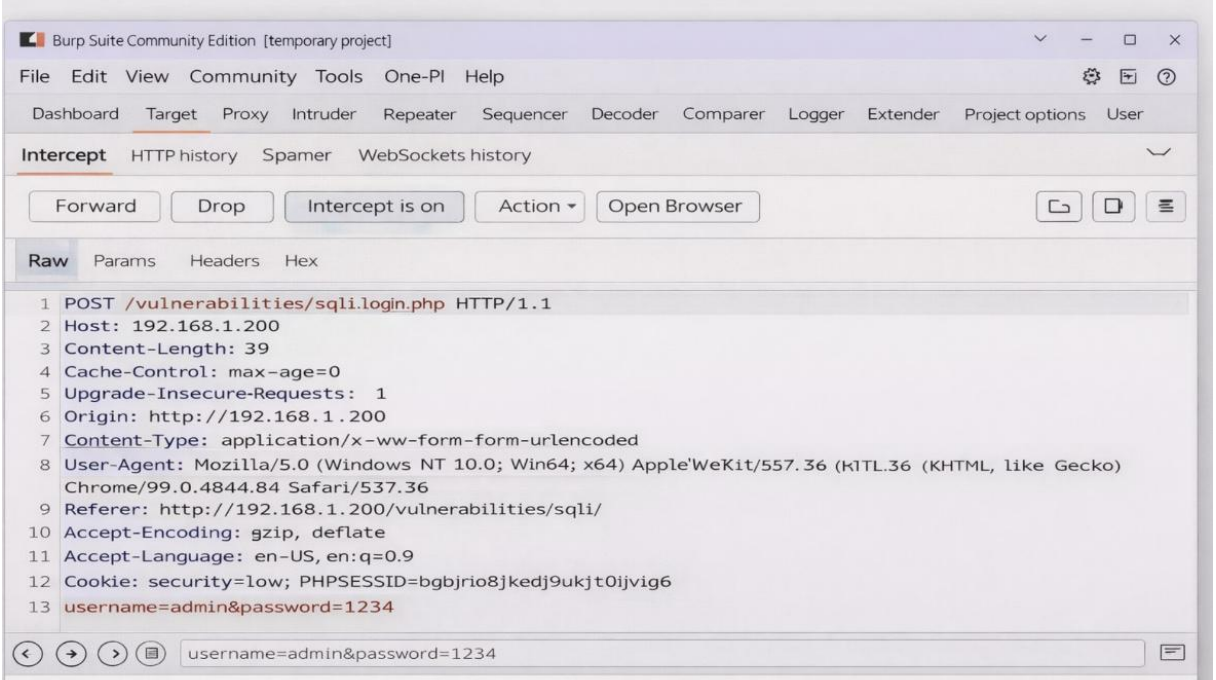


Figure 1: Target web aplication (Metasploitable2) login interface

Tools Used

1. Burp Suite

Burp Suite is used to intercept and modify HTTP requests. It helps in analyzing session tokens and testing vulnerabilities like authentication flaws and parameter manipulation.



"Figure 4: HTTP request intercepted by Burp Suite showing credentials passed in the clear

2. *Sqlmap*

Sqlmap is an automated tool used to detect and exploit SQL injection vulnerabilities in web applications.

3. OWASP ZAP

OWASP ZAP is a vulnerability scanner used to identify common security issues in web applications automatically.

Test Setup

1. *Target Application: DVWA (Damn Vulnerable Web Application)*
2. Target IP: 192.168.1.200

Vulnerability Log

This vulnerability log identifies two major security flaws in the tested web application. A critical SQL Injection vulnerability exists in the login page, allowing potential database compromise. Additionally, a medium severity reflected XSS vulnerability is present in the form page, which may lead to client-side attacks. Immediate remediation is recommended to secure the application.

Test ID	Vulnerability	Severity	Target URL
001	SQL Injection	Critical	http://192.168.1.200/login
002	XSS Reflected	Medium	http://192.168.1.200/form

Testing Methodology

1. SQL Injection Testing (Automated)

1. Used sqlmap tool to test input fields
2. Command used:

sqlmap -u "http://192.168.1.200/login" --dbs

3. Database information was successfully extracted

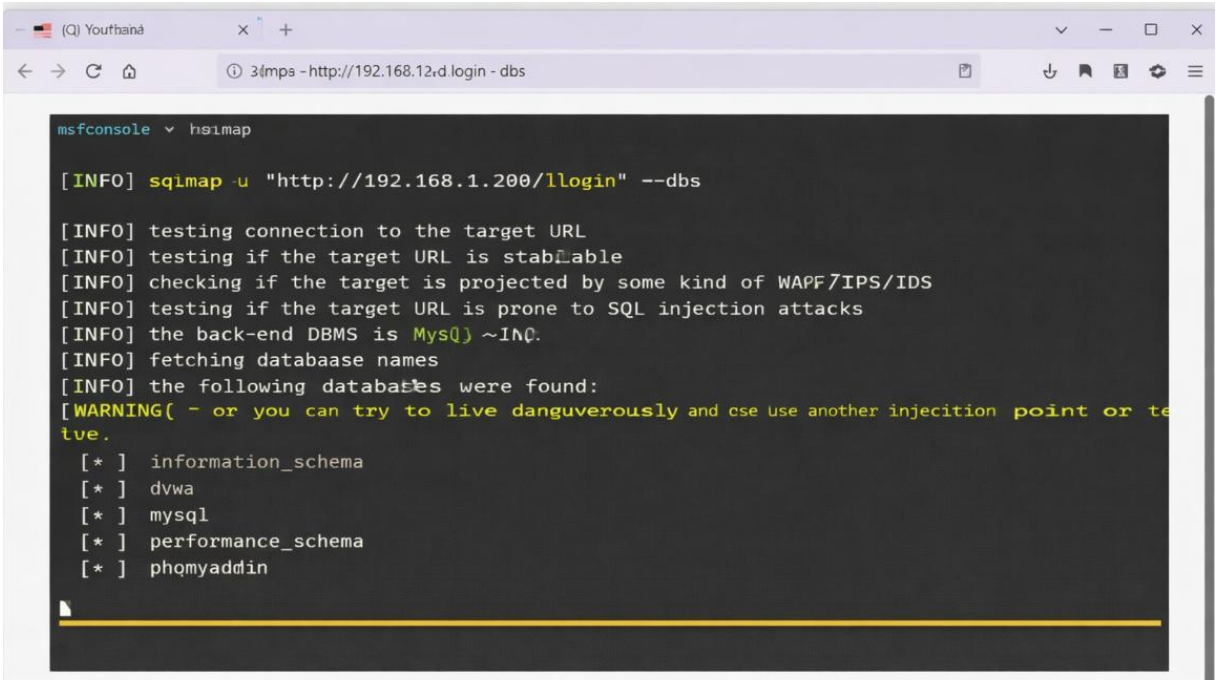


Figure 5: SQL Injection vulnerability exploited using sqlmap

2. XSS Testing (Manual)

1. Injected payload:

<script>alert('XSS')</script>

2. Alert popup confirmed vulnerability

Burp Suite Testing

Burp Suite is used as an intercepting proxy to capture and analyze HTTP/HTTPS requests between the browser and the web server. In this lab, Burp Suite was configured to intercept requests, allowing modification of parameters such as user IDs and session cookies. This helped in identifying vulnerabilities like insecure session management, parameter tampering, and potential IDOR issues.
Key use:
1. Intercept requests
2. Modify parameters
3. Analyze responses

Checklist

The checklist ensures that all important web vulnerabilities are tested systematically during the assessment.

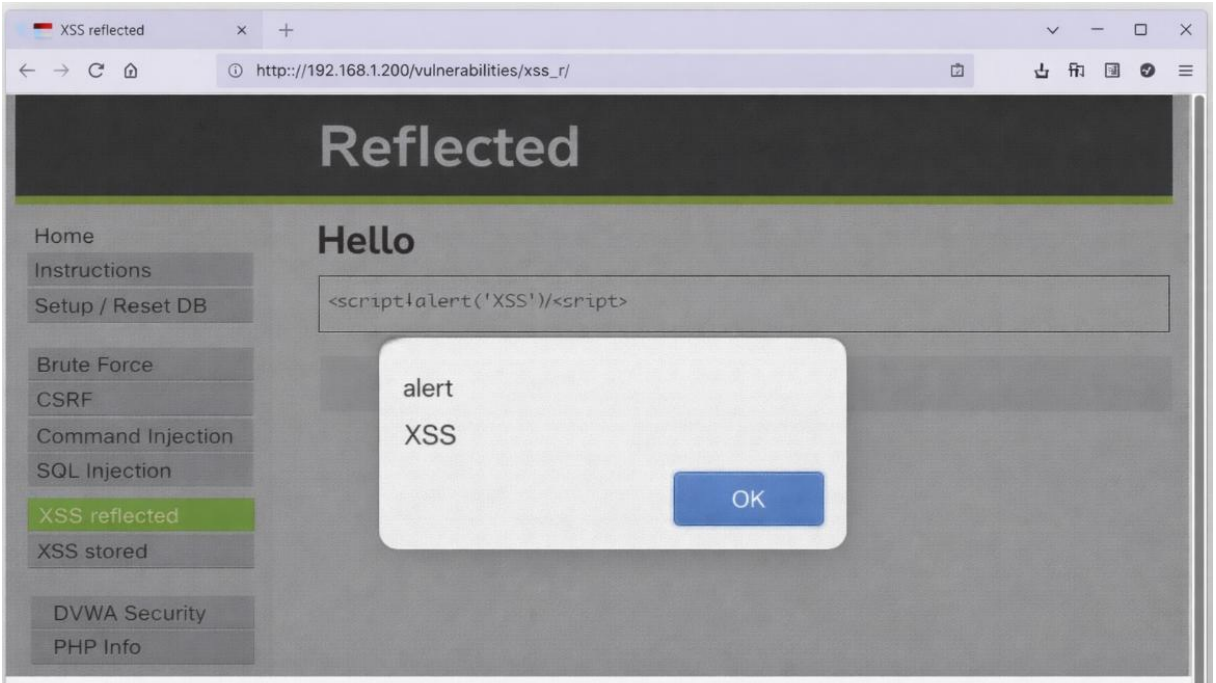


*Figure 6: Cross—site scripting vulnerability exploited via JavaScript alert popup

SQL Injection Testing:
Used sqlmap to detect database-related vulnerabilities.

XSS Testing:
Injected JavaScript payloads to check for script execution.

Self-Curated Scripts
Custom scripts can be used to automate repeated testing tasks.

Authentication Testing:
Checked for weak passwords, session issues, and improper login controls.

Findings

The testing process revealed multiple vulnerabilities in the web application
SQL Injection: Allows attackers to manipulate database queries and access sensitive data.
Cross-Site Scripting (XSS): Enables execution of malicious scripts in the user's browser.
Authentication Weaknesses: Improper login controls may allow unauthorized access.
These vulnerabilities can lead to data breaches and system compromise if not fixed.

Remediation

To secure the application, the following measures are recommended:
Input Validation: Validate and sanitize all user inputs to prevent malicious data.
Prepared Statements: Use parameterized queries to prevent SQL Injection.
Output Encoding: Encode user inputs before displaying to prevent XSS.
Secure Authentication: Implement strong password policies and session management.
Applying these fixes will reduce security risks and improve application safety.

Conclusion

The lab demonstrated the identification of critical web vulnerabilities using both manual and automated techniques. It highlighted the importance of secure coding practices and regular security testing to protect web applications from attacks.

Summary

The web application testing identified critical vulnerabilities including SQL injection and reflected XSS. Both manual and automated tools were used to validate security flaws. Burp Suite helped in request manipulation and session testing. Proper input validation, secure coding, and strong authentication mechanisms are recommended to enhance application security.